

Multi-Account GitHub OIDC — Implementation Guide

Centralize CI/CD identity in a Security account; workload accounts trust only that hub. GitHub Actions never holds AWS keys and never trusts workload accounts directly.

```
GitHub Actions runner
| (1) OIDC token, aud=sts.amazonaws.com
v
Security account -- OIDC provider -- HubRole (AssumeRoleWithWebIdentity)
| (2) sts:AssumeRole + ExternalId + SourceIdentity
v
Workload account -- SpokeRole -- deploy permissions (ECS / S3 / ECR / ...)
```

Hub trust policy (Security account)

Only federated GitHub principals whose **aud**, **repository_owner**, and **sub** claims all match can assume the hub role.

```
{"Principal": {"Federated": "<OIDC-ARN>"},
 "Action": "sts:AssumeRoleWithWebIdentity",
 "Condition": {
   "StringEquals": {
     "...:aud": "sts.amazonaws.com",
     "...:repository_owner": "Odisena"},
   "StringLike": {
     "...:sub": [
       "repo:Odisena/*:ref:refs/heads/main",
       "repo:Odisena/*:environment:prod"]}
 }}
```

Spoke trust policy (each workload account)

Trusts the hub role only. Requires **ExternalId** (rotated secret) and permits **sts:SetSourceIdentity** so the originating GitHub subject is stamped into every downstream CloudTrail event.

```
{"Principal": {"AWS": "arn:aws:iam::<SEC>:role/HubRole"},
 "Action": ["sts:AssumeRole", "sts:SetSourceIdentity"],
 "Condition": {"StringEquals": {
   "sts:ExternalId": "<rotated-secret>"},
 "StringLike": {
   "sts:SourceIdentity":
     "repo:Odisena/*:environment:*"}
 }}
```

Role chaining requirements

- Hub role has **no** deploy permissions — only **sts:AssumeRole** to the spokes.
- Chained sessions are capped at **1 hour**; set `max_session_duration=3600`.
- Preserve **SourceIdentity** across the chain so CloudTrail attributes every call to a GitHub subject.
- `ExternalId` is a defense-in-depth secret; store it in a per-repo GitHub Environment secret and rotate quarterly.
- Add a permissions boundary on spoke roles to cap blast radius even if the inline policy drifts.

Workflow changes vs. single-account

```
permissions:
  contents: read
  id-token: write

steps:
  # 1) OIDC -> hub role
  - uses: aws-actions/configure-aws-credentials@v4
    with:
      role-to-assume: ${vars.AWS_HUB_ROLE_ARN}
      aws-region: us-east-1

  # 2) chain hub -> spoke (role-chaining: true)
  - uses: aws-actions/configure-aws-credentials@v4
    with:
      role-to-assume: ${vars.AWS_SPOKE_ROLE_ARN_PROD}
      role-chaining: true
      role-external-id: ${secrets.SPOKE_EXTERNAL_ID}
      aws-region: us-east-1
```

Governance you get for free

- **One** OIDC trust surface to audit — the hub trust policy.
- Add/remove repos org-wide by editing the hub role's `allowed_subjects`.
- Rotate `ExternalId` to revoke a workload account without touching GitHub.
- CloudTrail in every account shows `SourceIdentity = repo:Org/Repo:env:prod`.
- Detective control: CloudTrail alert on `AssumeRoleWithWebIdentity` where `sub` is outside the allow-list.

References: [GitHub — Configuring OIDC in AWS](#) · [aws-actions/configure-aws-credentials \(role-chaining\)](#) · [AWS — Monitoring role activity via SourceIdentity](#)